

MERIDIAN HEALTH ANALYTICS, INC. — THIRD-PARTY / VENDOR RISK ASSESSMENT

Sample GRC portfolio artifact | Fictional company | Vendor inventory, risk tiering, and assessment status | Assessment dates are fictional scenario dates.

Vendor ID	Vendor Name	Service Provided	Data Accessed	PHI/PII Access?	Inherent Risk Tier	SOC 2 Type II on File?	Last Assessment Date	Assessment Score (0-100)	Risk Rating	Contract Renewal Date
V-001	ClaimLink Corp	Claims clearinghouse / eligibility verification	PHI, claims data	Yes	Critical	No	2025-11-03	84	Medium	2026-01-15
V-002	AWS (Amazon Web Services)	Cloud infrastructure hosting (IaaS)	PHI, all production data	Yes	Critical	Yes	2025-10-14	96	Low	2027-03-01
V-003	Okta	Identity provider / SSO	Authentication metadata, employee/user identities	No	High	Yes	2025-12-02	91	Low	2026-11-01
V-004	PayStream Processing	Payment processing gateway	Payment card data (tokenized), billing info	No	High	Yes	2025-09-18	88	Low	2026-09-15
V-005	SendGrid (Twilio)	Transactional email delivery	Email addresses, appointment reminders (limited PHI in subject lines)	Yes	High	Yes	2025-10-29	79	Medium	2026-06-30
V-006	DataVault Records Mgmt	Offsite physical records storage/destruction	Archived paper PHI records	Yes	High	No	2025-08-21	65	High	2026-04-01
V-007	QuickHire Staffing	Temporary/contract staffing agency	Employee background info (non-PHI)	No	Medium	No	2025-11-19	58	High	2026-08-01
V-008	CleanCo Facilities	Office cleaning services (after-hours facility access)	Physical facility access only	No	Low	No			Not Assessed	2026-12-01
V-009	Figma Inc.	Product design collaboration tool	Product mockups, no PHI	No	Low	Yes	2026-01-12	90	Low	2027-01-15
V-010	BillWise Revenue Cycle	Outsourced billing/revenue cycle management	PHI, billing and claims data	Yes	Critical	Partial (bridge letter only)	2025-12-16	71	High	2026-05-01
V-011	Zoom Video Communications	Video conferencing, incl. telehealth-adjacent internal meetings	Occasional PHI discussed in meetings (not recorded)	Yes	Medium	Yes	2026-02-04	93	Low	2027-02-01

VENDOR SECURITY QUESTIONNAIRE — ClaimLink Corp (V-001)

Completed by vendor point of contact | Reviewed by Vendor Risk Manager | Based on SIG Lite / HECVAT-style structure

#	Domain	Question	Vendor Response
1	Governance	Does the organization have a documented, board-approved information security policy reviewed at least annually?	Yes — policy last reviewed October 2025
2	Governance	Is there a designated individual or team responsible for information security (e.g., CISO)?	Yes — Director of Information Security, reports to COO
3	Compliance	Has the organization completed a SOC 2 Type II audit within the last 12 months?	No — most recent SOC 2 Type II report is dated 18 months ago; renewal in progress, expected completion Q2 2026
4	Compliance	Is the organization subject to and compliant with HIPAA as a Business Associate?	Yes — BAA executed with Meridian Health Analytics; internal HIPAA compliance program in place
5	Data Protection	Is data encrypted at rest using AES-256 or equivalent?	Yes — all PHI encrypted at rest via AWS KMS
6	Data Protection	Is data encrypted in transit using TLS 1.2 or higher?	Yes — TLS 1.2 enforced on all external endpoints
7	Access Control	Is multi-factor authentication required for all remote and administrative access?	Yes — MFA enforced via Okta for all employee accounts
8	Access Control	Are access reviews performed on a recurring basis (at minimum quarterly)?	Access reviews performed semi-annually, not quarterly
9	Incident Response	Is there a documented incident response plan, and when was it last tested?	Documented IR plan exists; last tabletop test 14 months ago
10	Incident Response	What is the contractual notification timeline in the event of a breach involving our data?	Vendor contract specifies notification within 5 business days of confirmed breach
11	Business Continuity	Is there a documented and tested business continuity / disaster recovery plan?	BC/DR plan documented; last full test 20 months ago
12	Subcontractors	Does the organization use subcontractors (fourth parties) with access to our data, and are they contractually flowed down the same security requirements?	Yes, one subcontractor (cloud hosting); security requirements flowed down via subcontractor agreement

Assessor Findings

- No current SOC 2 Type II report on file (renewal in progress) — drives Critical/High risk rating pending receipt.
- Access reviews at semi-annual cadence fall short of internal quarterly standard for Critical-tier vendors — flagged as a contractual follow-up item.
- BC/DR test cadence (20 months) exceeds internal 12-month expectation for Critical-tier vendors handling PHI.
- Overall assessment score: 84/100 (Medium-High). Recommend conditional approval pending SOC 2 Type II delivery within 90 days; tracked as Risk R-003 in the enterprise Risk Register.

VENDOR RISK SCORING METHODOLOGY

Inherent Risk Tiering	Critical = PHI/PII + system access High = sensitive data, no direct PHI Medium = limited/indirect data exposure Low = no sensitive data access
Assessment Score	0-100 composite score from security questionnaire responses, weighted toward Data Protection, Access Control, and Compliance domains (40%/30%/30%)
Risk Rating Logic	Critical tier + score < 80 = High risk Any tier scoring < 70 = High Score 70-84 = Medium Score >= 85 = Low No score on file = Not Assessed
Reassessment Cadence	Critical tier: annually + upon SOC 2 report renewal High tier: annually Medium/Low tier: every 18-24 months or upon material service change
Escalation	High-risk vendors require Vendor Risk Manager + Compliance Officer sign-off to continue the relationship, with a documented remediation plan and re-assessment date.